

잠글 곳과 열어둘 곳을 선으로 설명하다

플랜두씨 다이어리의 네트워크, 인증 세션, 요청 보호, 소유권, 이관과 운영
증거

SESSION

Access JWT + DB refresh session

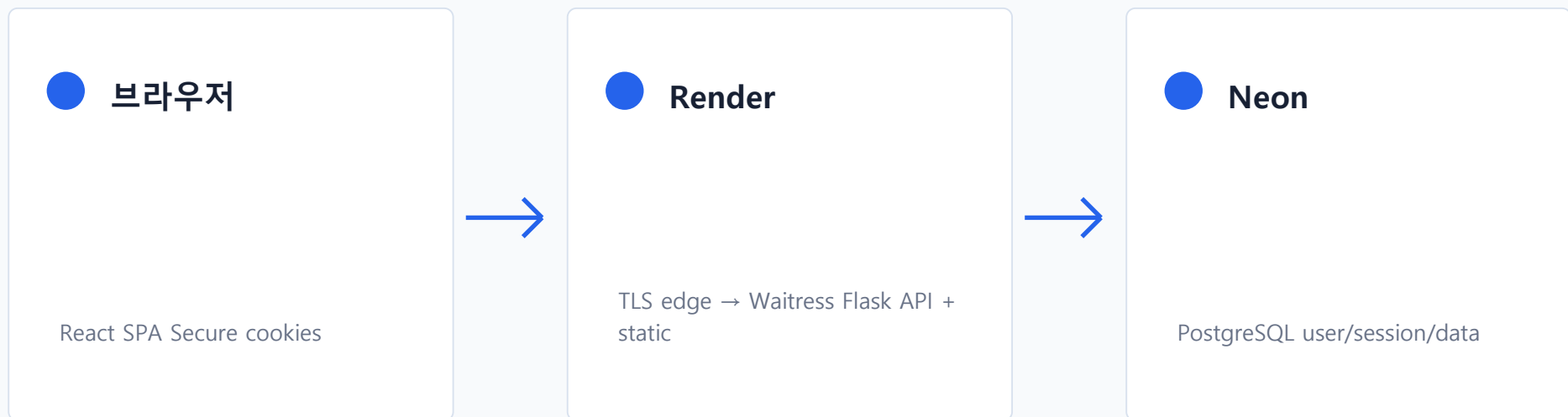
PASSWORD

Argon2id · 19,456KiB · t=2 · p=1

OBSERVATION

2026-09-07 — 09-11 · 5 days

요청은 세 경계를 통과한다



공개 예외는 `/api/live/api/health`뿐이다. SPA 하위 경로는 `allowlist`로만 셀을 반환하며, 오타 난 API는 404다.

서명과 서버 행을 함께 확인한다

STEP 1

로그인

Argon2id 검증 없는 이메일은
dummy verify

STEP 2

세 쿠키

Access · Refresh · CSRF
URL:localStorage 사용 안 함

STEP 3

요청 가드

JWT 서명·exp·sid·sub DB 세션
생존 확인

STEP 4

회전·폐기

Refresh 매 사용 회전 재사용 시
계열 폐기

수명

Access 10분 · 유효 48시간 · 절대 14일

즉시 로그아웃

sid 세션 행 폐기 → 기존 Access도 401

상태 변경은 세 겹으로 거른다

JSON

단순 HTML form 모양 차단

Content-Type application/json

ORIGIN

이 배포 출처만 허용

Render TLS proxy scheme 반영

CSRF

읽을 수 있는 값만 헤더로 복사

세션 쿠키 없이는 권한이 아님

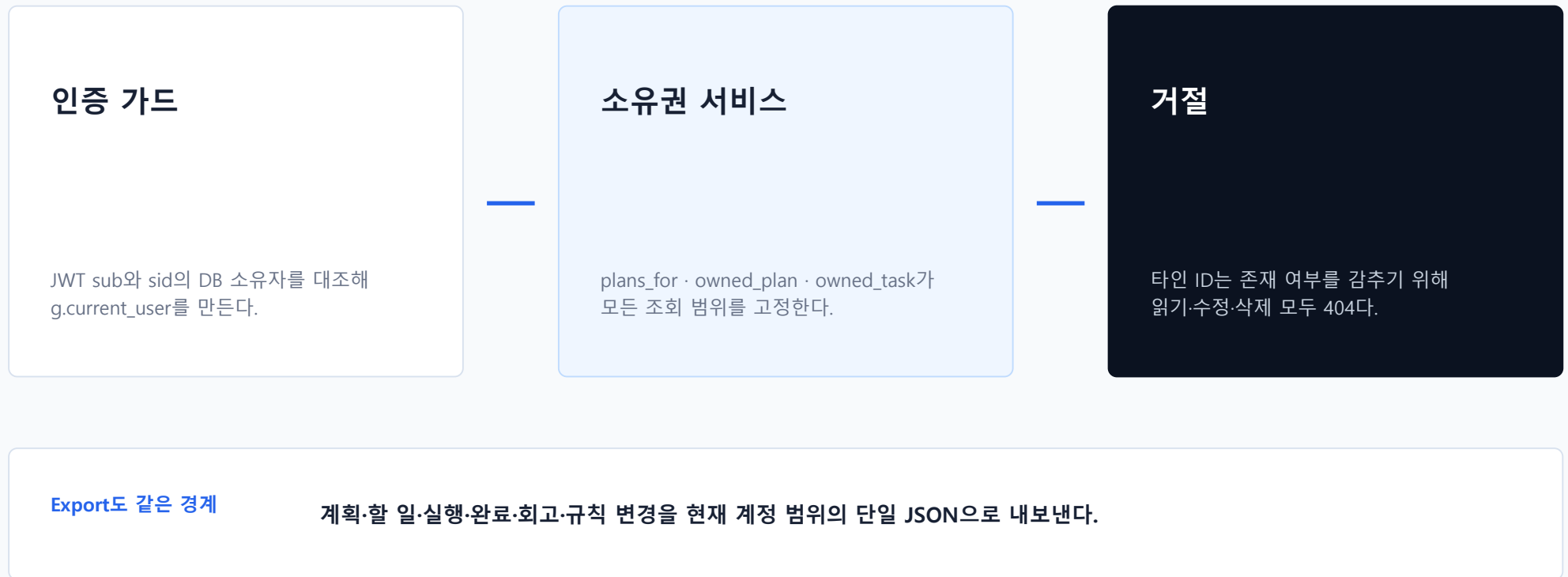
정상 요청 2xx

토큰 없음·불일치·교차 출처는 403

JSON 아님은 415

GET/HEAD는 안전해야 하며,
상태를 바꾸는 GET은 만들지
않는다

클라이언트가 보낸 사용자 ID를 믿지 않는다



백업 → claim → NOT NULL 순서를 지킨다

BACKUP

Neon branch

backup-20260905-before-t07
-claim

SCHEMA 1

user_id nullable

기존 T06 행을 먼저 읽을 수
있게

CLAIM

계획 3건

고정 계정 소유권 부여 ·
미소유 0

SCHEMA 2

user_id NOT NULL

소유권 없는 새 행을 DB가
거절

BOOT

none

일회성 작업 재실행 방지

운영 결과

Alembic heads c48b1f60a2d7 + d5a3e91c7f20 · /api/live 200 · 익명 /api/auth/me 401

실패를 포함한 결과를 같은 표에 남긴다

장면	성공	거절·검산
로그아웃 재사용	200	같은 쿠키 401
타인 자료 읽기	본인 200	양방향 404
타인 자료 변경	본인 성공	PATCH·DELETE 404
Refresh 회전	후계 1개	이전 값 재사용 → 계열 폐기
실제 관찰	5 dates	50/90 = 0.56배

최종 검사 319 passed · 3 PostgreSQL-only skips · frontend 76 passed · secret audit 0 findings

막지 않은 위험도 제출물에 포함한다

이메일 소유 확인 없음

남의 주소로 가입 가능

비밀번호 재설정 없음

분실 시 계정 복구 불가

가입 속도 제한 없음

대량 계정 생성 가능

회전 응답 유실

이전 Refresh 재시도 시 재로그인

세션 단위 폐기

Access 하나만 선택 폐기 불가

복잡도 규칙

예측 가능한 치환을 유도할 수 있음

범위 판단

일반 사용자용 인증 서비스의 완성형이 아니라, 실패 경로와 한계를 재현 가능한 학습 구현으로 고정했다.